DEVOPS SECURITY

Infrastructure Security

Lecture 04 · Cloud, Network & Identity Security

AYESHA WIJESOORIYA

LECTURE 04

Learning Outcomes

At the end of this lecture, students should be able to:

- Explain the importance of infrastructure security in DevSecOps environments.
- Describe cloud infrastructure security concepts and responsibilities.
- Apply network security principles to protect cloud-based applications.
- Explain Identity and Access Management (IAM) concepts in cloud platforms.
- Identify secure configuration management practices and system hardening techniques.
- Recommend security controls for protecting cloud infrastructure.

LECTURE 04

Lecture Overview

1. Securing Cloud Infrastructure
2. Network Security Principles and Controls
3. Identity and Access Management (IAM)
4. Secure Configuration Management and Hardening

01

SECTION

Introduction to Infrastructure Security

What Is Infrastructure Security?

Infrastructure Security is the practice of protecting the underlying technology that supports applications, services, and organizational operations.

It involves implementing security controls to safeguard physical and virtual infrastructure components against cyber threats, unauthorized access, system failures, and data breaches.

Unlike application security, which focuses on protecting software applications, infrastructure security protects the environment where those applications are deployed and executed.

What Infrastructure Security Protects

Infrastructure security spans many components, in pursuit of clear objectives:

Includes

- Physical servers and data centers
- Virtual machines (VMs)
- Cloud infrastructure
- Networks
- Operating systems
- Databases
- Storage systems
- Containers
- Identity management systems
- Network devices — routers, switches, firewalls

Objectives

- Protect infrastructure from cyber attacks
- Prevent unauthorized access
- Ensure business continuity
- Maintain system availability
- Protect sensitive organizational data
- Reduce operational risks
- Support regulatory and compliance requirements

Infrastructure Components

Modern IT infrastructure consists of multiple layers a weakness in any layer can compromise the entire system.

Applications

Web applications, mobile applications, APIs, enterprise software

Containers & VMs

Docker containers, Kubernetes clusters, virtual machines

Operating Systems

Windows Server, Linux, Unix

Cloud Infrastructure

Compute instances, storage services, databases, load balancers

Network Infrastructure

Routers, switches, firewalls, VPN gateways, DNS services

Physical Infrastructure

Servers, data centers, storage devices, networking hardware

Defence in Depth for Infrastructure

Infrastructure security applies the principle of Defense in Depth, where multiple security controls are implemented across different layers.

- Firewalls
- Network segmentation
- Identity and Access Management (IAM)
- Encryption
- Multi-Factor Authentication (MFA)
- Intrusion Detection Systems (IDS)
- Secure configurations
- Continuous monitoring

By implementing multiple layers of defense, organizations reduce the likelihood that a single vulnerability will compromise the entire infrastructure.

02

SECTION

Securing Cloud Infrastructure (AWS & Azure)

What Is Cloud Computing?

Cloud computing is a computing model that provides on-demand access to shared computing resources - servers, storage, databases, networking, software, analytics, and security services - over the Internet, billed only for what is used.

Cloud computing enables organizations to rapidly deploy applications, scale resources on demand, reduce infrastructure costs, and improve business agility.

ANALOGY *"A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources that can be rapidly provisioned and released with minimal management effort." - NIST*

Essential Characteristics of Cloud Computing

- On-Demand Self-Service - users can provision computing resources without interacting with the cloud provider.
- Broad Network Access - resources are accessible over the Internet from various devices.
- Resource Pooling - physical resources are shared among multiple customers using virtualization.
- Rapid Elasticity - resources can automatically scale up or down based on demand.
- Measured Service - customers pay only for the resources they consume (pay-as-you-go).

Benefits and Challenges of Cloud Computing

Benefits

- Reduced infrastructure costs
- Faster application deployment
- High availability
- Automatic scalability
- Disaster recovery capabilities
- Global accessibility
- Improved operational efficiency

Challenges

- Data privacy concerns
- Cloud misconfigurations
- Vendor lock-in
- Compliance requirements
- Identity management
- Security of customer-managed resources

Cloud Service Models

Cloud services are categorized into three primary models, each defining how responsibility is shared between provider and customer.

Model	Description	Examples	Customer Responsibility
IaaS	Virtualized computing resources: VMs, storage, networking.	AWS EC2, Azure VMs, Google Compute Engine	OS, applications, data, IAM, configurations
PaaS	A complete application platform without managing underlying infrastructure.	Azure App Service, Google App Engine, AWS Elastic Beanstalk	Application code, data, user access
SaaS	Fully managed software applications delivered over the Internet.	Microsoft 365, Gmail, Salesforce	User management, data usage, access control

IaaS vs. PaaS vs. SaaS

Feature	IaaS	PaaS	SaaS
Manage servers	Yes	No	No
Manage operating system	Yes	No	No
Deploy applications	Yes	Yes	No
Manage data	Yes	Yes	Limited
Customer control	Highest	Medium	Lowest

Cloud Deployment Models

Public Cloud

Owned and managed by a third-party provider, shared among multiple customers (AWS, Azure, Google Cloud).

ADVANTAGES

- Cost-effective
- Highly scalable
- Easy deployment

DISADVANTAGES

- Less direct control
- Compliance concerns for sensitive data

Private Cloud

Cloud infrastructure dedicated to a single organization.

ADVANTAGES

- Greater control
- Enhanced security
- Better compliance

DISADVANTAGES

- Higher operational costs
- Requires dedicated management

Hybrid Cloud

Combines public and private cloud - sensitive data stays private, other workloads use public cloud.

ADVANTAGES

- Flexibility
- Cost optimization
- Improved disaster recovery

Multi-Cloud

Uses services from multiple providers, e.g. AWS for compute, Azure for identity, Google Cloud for AI.

ADVANTAGES

- Reduces vendor lock-in
- Increases resilience
- Best-of-breed services

Shared Responsibility Model

The Shared Responsibility Model defines how security duties are divided between cloud provider and customer.

Cloud Provider - Security OF the Cloud

- Physical data centers
- Physical servers
- Storage hardware
- Networking infrastructure
- Hypervisors
- Cloud platform services

Customer - Security IN the Cloud

- Operating systems (IaaS)
- Applications
- User accounts
- IAM policies
- Data
- Network configurations
- Virtual machines
- Encryption settings
- Security groups and firewall rules

Cloud Security Challenges (1/2)

Misconfiguration

Incorrect security settings expose resources. Examples: publicly accessible storage buckets, open security groups, weak IAM policies.

Data Breaches

Sensitive information exposed via poor controls or compromised accounts - customer databases, financial records, personal information.

Weak IAM

Excessive permissions or poor authentication increase risk - shared admin accounts, lack of MFA, overly permissive policies.

Cloud Security Challenges (2/2)

Insecure APIs

Weak authentication, improper authorization, or poor input validation can let attackers exploit cloud resources.

Insider Threats

Employees or contractors with legitimate access may intentionally or unintentionally compromise resources.

Account Hijacking

Attackers steal credentials or session tokens to gain unauthorized access to cloud environments.

Denial of Service

Attackers overwhelm cloud services with excessive requests, affecting availability.

Compliance & Regulatory

Organizations must comply with GDPR, HIPAA, or PCI DSS when storing and processing data in the cloud.

Cloud Security Principles

Least Privilege

Grant users and services only the permissions necessary to perform their tasks.

Defense in Depth

Layer IAM, firewalls, encryption, monitoring, and backups.

Secure by Default

Configure resources with secure defaults; disable unnecessary services.

Encryption Everywhere

Protect data at rest, in transit, and during backup.

Continuous Monitoring

Use logs, alerts, and automated detection to identify suspicious activity.

Automation

Automate patching, config validation, security scanning, and compliance checks.

AWS Security Overview

Amazon Web Services (AWS) provides a wide range of security services that help organizations protect their cloud infrastructure.

- Identity and Access Management (IAM)
- Encryption using AWS Key Management Service (KMS)
- Continuous monitoring with Amazon CloudWatch
- Audit logging using AWS CloudTrail
- Threat detection with Amazon GuardDuty
- Security posture management using AWS Security Hub
- Vulnerability assessment with Amazon Inspector
- Secrets management using AWS Secrets Manager

AWS follows the Shared Responsibility Model and provides customers with tools to build secure cloud environments.

AWS Security Services

Service	Purpose
AWS IAM	Manage users, groups, roles, and permissions.
AWS CloudTrail	Record and audit API activities performed within AWS.
Amazon CloudWatch	Monitor infrastructure performance, logs, and events.
Amazon GuardDuty	Detect malicious activity using machine learning and threat intelligence.
AWS Security Hub	Centralize security findings from multiple AWS services.
AWS Inspector	Scan workloads for vulnerabilities and configuration issues.
AWS KMS	Create and manage encryption keys.
AWS Secrets Manager	Securely store passwords, API keys, and other secrets.

AZURE

Microsoft Azure Security Overview

Azure follows the Shared Responsibility Model and builds security around three main principles.

Built Around

- Protect Identities - only authorized users and services can access resources.
- Protect Data - encryption, backup, and access controls.
- Protect Infrastructure - monitor, detect, and respond to threats.

Advantages of Azure Security

- Integrated identity management
- Built-in security monitoring
- Advanced threat protection
- Automated compliance assessment
- Strong encryption support
- Continuous vulnerability management

Microsoft Azure Security Services

Service	Purpose
Microsoft Entra ID (Azure AD)	Identity and access management for users and applications.
Microsoft Defender for Cloud	Identifies vulnerabilities, recommends improvements, detects threats.
Azure Key Vault	Securely stores encryption keys, certificates, passwords, and secrets.
Azure Monitor	Collects performance metrics, logs, and alerts.
Azure Policy	Enforces organizational security and compliance policies.
Microsoft Sentinel	Cloud-native SIEM and SOAR for threat detection and response.
Azure Firewall	Managed firewall filtering traffic to and from Azure resources.

Why Is Data Protection Important?

Data is one of an organization's most valuable assets - and one of the most targeted. In the cloud, data is created, moved, and stored across many services, widening the opportunity for exposure.

Effective data protection preserves customer trust, meets legal and regulatory obligations, and limits the financial and reputational damage of a breach.

Data Protection Principles - Encryption & Access Control

Data Encryption

- Converts readable information into unreadable ciphertext.
- Encryption at Rest - protects stored data (AWS KMS, Azure Key Vault).
- Encryption in Transit - protects data crossing networks (HTTPS, TLS, VPN).

Access Control

- Only authorized users should access sensitive data.
- Identity and Access Management (IAM)
- Role-Based Access Control (RBAC)
- Multi-Factor Authentication (MFA)
- Principle of Least Privilege

Data Classification & Backup / Recovery

Data should be classified by sensitivity, and secure backups maintained for recovery.

Data Classification

- Public - company website
- Internal - employee handbook
- Confidential - customer database
- Highly Confidential - credit card data, medical records

Backup & Recovery - protects against

- Accidental deletion
- Hardware failures
- Ransomware attacks
- Natural disasters

Cloud Logging and Monitoring

Preventing every cyber attack is impossible. Organizations must continuously monitor their cloud environments to detect suspicious activities, identify security incidents, and respond quickly.

Monitoring provides visibility into what is happening within the cloud environment.

MONITORING

Security Monitoring Activities

Organizations should monitor:

- **User login attempts**
- **Failed authentication attempts**
- **Administrative actions**
- **Changes to security groups**
- **Configuration changes**
- **Network traffic**
- **API requests**
- **Resource utilization**
- **Application logs**

Monitoring Services and Benefits

Monitoring Services

- AWS CloudTrail - records API activity and user actions
- AWS CloudWatch - monitors infrastructure performance and logs
- AWS GuardDuty - detects suspicious activity
- Azure Monitor - performance metrics, logs, alerts
- Microsoft Defender for Cloud - vulnerability & threat detection
- Microsoft Sentinel - SIEM and SOAR

Benefits of Monitoring

- Early threat detection
- Faster incident response
- Compliance reporting
- Performance optimization
- Audit support
- Improved operational visibility

Backup and Disaster Recovery

Data loss can occur due to cyber attacks, hardware failures, accidental deletion, software errors, or natural disasters. Regular backups ensure organizations can recover critical data and continue operations.

- Perform regular backups.
- Encrypt backup data.
- Store backups in multiple locations.
- Test backup restoration procedures regularly.
- Restrict access to backup repositories.
- Monitor backup jobs.

RESILIENCE

Disaster Recovery - RTO & RPO

Disaster Recovery (DR) restores IT services after a major disruption. A DR plan defines recovery procedures, responsibilities, priorities, communication plans, and business continuity measures.

Recovery Time Objective (RTO)

The maximum acceptable time required to restore a system after a disruption.

Example: The online banking application must be restored within 2 hours.

Recovery Point Objective (RPO)

The maximum acceptable amount of data loss, measured in time.

Example: No more than 15 minutes of transaction data may be lost.

03

SECTION

Network Security Principles and Controls

What Is Network Security?

Network Security is the practice of protecting computer networks, communication channels, and connected devices from unauthorized access, misuse, attacks, and data breaches.

In a DevSecOps environment, network security protects communication between users, applications, databases, microservices, containers, VMs, cloud resources, APIs, and external services.
Without proper network security, attackers can intercept sensitive information, gain unauthorized access, disrupt services, or move laterally through an organization's infrastructure.

Objectives and Common Threats

Distributed applications across cloud, containers, APIs, and microservices make network security essential to prevent exploitation of exposed services.

Objectives

- Prevent unauthorized network access
- Protect sensitive information in transit
- Maintain confidentiality, integrity, availability (CIA)
- Detect and prevent malicious activities
- Ensure reliable communication between systems
- Reduce the impact of cyber attacks

Common Threats

- Unauthorized access
- Malware propagation
- Denial of Service (DoS/DDoS)
- Man-in-the-Middle (MitM) attacks
- Packet sniffing
- IP spoofing
- DNS attacks
- Session hijacking
- Insider attacks

The CIA Triad in Network Security

The CIA Triad forms the foundation of information security and guides the design of secure networks.

Confidentiality

Only authorized parties can view data as it moves across the network - enforced through encryption and access control.

Integrity

Data is not altered in transit or at rest - enforced through hashing, checksums, and digital signatures.

Availability

Network resources remain accessible to legitimate users - protected against DoS/DDoS and outages.

Network Security Controls

Network security controls are technologies, policies, and procedures that protect networks from cyber threats, grouped into three categories:

Preventive Controls

Prevent attacks before they occur.

- Firewalls
- VPNs
- Access Control Lists
- Multi-Factor Authentication
- Network Segmentation

Detective Controls

Identify attacks while, or after, they occur.

- Intrusion Detection Systems (IDS)
- SIEM
- Log Monitoring
- Network Monitoring Tools

Corrective Controls

Reduce impact and restore normal operations.

- Backup and Recovery
- Patch Management
- Incident Response
- Disaster Recovery

Common Network Security Technologies

- Firewalls
- IDS
- IPS
- VPN
- Web App Firewall (WAF)
- Proxy Servers
- DNS Security
- Network Access Control
- Secure Gateways

Firewalls

A firewall is a network security device or software application that monitors, filters, and controls incoming and outgoing network traffic based on predefined security rules.

Firewalls act as the first line of defense by blocking unauthorized traffic while allowing legitimate communication.

Types of Firewalls

Packet Filtering

Examines individual packets using source IP, destination IP, port number, and protocol. Simple but limited.

Stateful Firewall

Tracks active network connections and makes decisions based on connection state. More secure than packet filtering.

Next-Gen Firewall (NGFW)

Adds application awareness, intrusion prevention, malware detection, user identity awareness, and SSL inspection.

Web App Firewall (WAF)

Protects web applications from SQL injection, XSS, command injection, and file inclusion by inspecting HTTP/HTTPS traffic.

Intrusion Detection & Prevention Systems

IDS

Intrusion Detection System

- Monitors network traffic for suspicious activity or known attack patterns.
- Generates alerts when an attack is detected.
- Does not stop the attack.

IPS

Intrusion Prevention System

- Monitors traffic and automatically blocks malicious activity in real time.
- Deployed inline, actively protecting the network.
- Can drop malicious packets.

IDS vs. IPS at a Glance

IDS	IPS
Detects attacks	Detects and blocks attacks
Generates alerts	Automatically prevents attacks
Passive monitoring	Active protection
Does not interrupt traffic	Can drop malicious packets

Types of Detection

Signature-Based Detection

- Detects known attacks using predefined attack signatures.
- Advantage: accurate for known threats.
- Limitation: cannot detect new attacks.

Anomaly-Based Detection

- Detects abnormal behavior against a normal baseline.
- Advantage: can detect unknown attacks.
- Limitation: higher false-positive rate.

Virtual Private Network (VPN)

A VPN creates an encrypted communication channel between users and organizational resources over an untrusted network such as the Internet, providing secure remote access while protecting transmitted data from interception.

- Encrypts network traffic
- Protects sensitive information
- Enables secure remote work
- Prevents packet sniffing
- Protects public Wi-Fi connections

Common technologies: IPsec, SSL VPN, WireGuard, OpenVPN.

Types of VPN

Remote Access VPN

- Allows individual users to securely connect to organizational networks.

Example: Employees working from home.

Site-to-Site VPN

- Connects two geographically separate networks securely.

Example: A company headquarters connected to branch offices.

04

SECTION

Identity and Access Management (IAM) in the Cloud

What Is Identity and Access Management?

IAM is a framework of policies, technologies, and processes used to manage digital identities and control access to organizational resources - ensuring the right user or system has the right access to the right resource at the right time.

In cloud computing, IAM is one of the most critical security mechanisms because resources are accessible over the Internet. IAM manages both human identities (employees, administrators, customers) and non-human identities (applications, VMs, APIs, services).

Objectives of IAM

IAM aims to:

- Verify user identities.
- Control access to resources.
- Enforce the Principle of Least Privilege.
- Protect sensitive information.
- Reduce insider threats.
- Provide accountability through logging and auditing.
- Support regulatory compliance.

Why IAM Is Important in Cloud Security

Cloud environments are highly dynamic - new users, applications, and resources are constantly created and removed. IAM provides centralized control over these identities, ensuring only authorized entities can access cloud resources.

- Without IAM, anyone with credentials may access sensitive resources.
- Excessive permissions increase security risks.
- Stolen accounts can compromise cloud infrastructure.
- Organizations lose visibility over who accessed what and when.

Core Components of IAM

IAM consists of several key components that work together to control access.

Component	Description
Identity	A person, application, or service that requires access to resources.
Authentication	The process of verifying the identity of a user or service.
Authorization	Determines what an authenticated identity is allowed to do.
Users	Individual identities with credentials.
Groups	Collections of users with similar permissions.
Roles	A set of permissions assigned based on job functions.
Policies	Rules defining what actions are allowed or denied.
Permissions	Specific actions that can be performed on cloud resources.

Access Control Models - RBAC

Role-Based Access Control (RBAC) assigns permissions to roles rather than individual users - widely used in cloud environments.

Role	Permissions
Student	View own results
Lecturer	Update module marks
Administrator	Manage users

ADVANTAGES

- Easy management
- Supports least privilege
- Widely used in cloud environments

Access Control Models - ABAC, DAC & MAC

ABAC

Access decisions are based on attributes: department, location, time, device, job title.

- "Only finance managers can access payroll information during office hours."

DAC

The resource owner decides who can access resources.

- A user shares a document with selected colleagues.

MAC

Access is determined by predefined security classifications.

- Government classified information.

Principle of Least Privilege (PoLP)

Users, applications, and services should receive only the minimum permissions required to perform their tasks. Cloud example - a developer's access:

Grant

- Read EC2 instances
- Deploy applications
- Restart application services

Do Not Allow

- Delete databases
- Modify IAM policies
- Manage billing

Multi-Factor Authentication (MFA)

MFA requires users to provide two or more independent authentication factors before access is granted. Even if attackers steal a password, they cannot easily access systems without the second factor.

Something You Know

Password, PIN

Something You Have

Mobile phone, security token, smart card

Something You Are

Fingerprint, face recognition, iris scan

Identity Federation and Single Sign-On (SSO)

Identity Federation

- Enables users to access multiple systems using identities managed by another trusted organization.

Example: Students use university credentials to access Microsoft Azure or Google Workspace.

Single Sign-On (SSO)

- Allows users to authenticate once and access multiple applications without logging in repeatedly.
- Benefits: improved user experience, fewer passwords, reduced password fatigue, centralized identity management.

Example: One login for LMS, Email, Microsoft Teams and the Library Portal.

AWS IAM

AWS Identity and Access Management enables administrators to securely manage access to AWS resources.

Components

- Users - individual identities
- Groups - collections of users
- Roles - temporary permissions for users or services
- Policies - JSON documents defining permissions

Best Practices

- Do not use the root account for daily activities.
- Enable MFA.
- Apply least privilege.
- Rotate credentials regularly.
- Use roles instead of long-term access keys.

IAM

Microsoft Entra ID (Azure AD)

Microsoft's cloud-based identity management service (formerly Azure Active Directory).

Provides

- Authentication
- Authorization
- Single Sign-On
- Multi-Factor Authentication
- Conditional Access
- Identity Protection

Features & Benefits

- Cloud identity management
- Device authentication
- Identity federation
- Risk-based authentication
- Access reviews
- Centralized, simplified administration

IAM Best Practices

Organizations should implement the following best practices:

Identity Management

Remove inactive accounts. Review permissions regularly. Use role-based access.

Authentication

Enable MFA. Enforce strong passwords. Disable shared accounts.

Authorization

Apply least privilege. Use temporary credentials. Separate administrative accounts.

Monitoring

Monitor login activities. Detect unusual behavior. Log privileged operations.

Credential Management

Rotate passwords regularly. Protect API keys. Store secrets securely.

Common IAM Threats and Misconfigurations

Poor IAM practices often lead to cloud security incidents.

Common Threats

- Credential theft
- Phishing attacks
- Password reuse
- Insider threats
- Privilege escalation
- Account hijacking

Common Misconfigurations

- Administrator permissions for all users
- Public access enabled unintentionally
- Inactive accounts not removed
- Shared administrator accounts
- Long-lived access keys
- Missing MFA

Security Recommendations

- Enable MFA
- Monitor privileged accounts
- Review permissions regularly
- Remove unnecessary accounts
- Apply least privilege
- Use identity monitoring tools

Q & A

Thank you